

Regulated RAG — threat and citation notes (mock)

Synthetic briefing for regulated RAG QA (NeuroGig mock). Not legal advice.

Threat model (summary)

Cross-tenant leakage: strict index separation per tenant_id. Prompt injection from user uploads: sanitize extracted text; never execute code embedded in retrieved chunks.

Citation policy

Any statement framed as "per policy X" must carry an anchor (file, page, snippet). Low retriever score requires an explicit refusal and a pointer to the policy owner.

Audit and retention

Assistant-driven document views append to an audit log (user, tenant, doc id, timestamp). Quarterly log export for compliance. Data-subject deletion tickets trigger index rebuild within 72 hours.

Red team

Fifty adversarial prompts are excluded from fine-tuning. Monthly staging runs; new critical findings block release until remediated.

Sign-off

Product owner, security officer, and DPO (if applicable) approve pilot in the segmented environment. Document version tracked alongside MOCK-PROJECTS data.

Operational metrics

Track refusal rate, average citation depth, and drift between keyword baseline and RAG answers. Alert if refusal rate drops sharply without an approved model change.